모의 해킹 프로젝트
결과 보고서

CMD

김서진 | 김관웅 | 이재민 | 배주형

Contents

1. Overview

1. 프로젝트 개요
2. 팀원 및 역할 분담
3. 프로젝트 진행 과정
4. 프로젝트 사용 도구
5. 시스템 인프라 구성

2. Web Security

1. 웹 페이지 소개
2. 웹 정보 수집
3. OWASP TOP 10 소개
4. 취약점 탐색 및 진단
5. 모의해킹 및 대응방안

3. Mobile Security

1. 모바일 앱 페이지 소개
2. 모바일 웹 정보 수집
3. OWASP TOP 10 소개
4. 취약점 탐색 및 진단
5. 모의해킹 및 대응방안

PART 1. PROJECT OVERVIEW

01 프로젝트 개요

"가상의 병원 SecuriCare의 Web page 및 Mobile 어플리케이션의 취약점 점검 및 보완을 위한 프로젝트"



진단 범위 (Scope)

- 대상 시스템
  - Web, Mobile
- 주요 서비스
  - 회원 관리 시스템
  - 게시판

핵심 내용 (Focus)

- 취약점 진단
- 취약점 분석
- 대응 방안 구현
- 대응 방안 결과



프로젝트 일정

- 2025.11.24 ~ 2025.12.24



기대 효과

- 보안 신뢰도 상승
- 잠재적 위협 제거

02 팀원 및 역할 분담

Common Task - OWASP Top 10 기반 취약점 탐색 및 진단
취약점에 대한 실질적 대응 방안 수립 및 적용

팀원	담당 업무	OWASP Web Top 10 취약점 공격	OWASP Mobile Top 10 취약점 공격
김서진	취약한 모바일 서버 인프라 환경 구축	A02: Broken Access Control, A09: Security Logging & Alerting Failure	M4: Insufficient Input/Output Validation
김관웅	취약한 웹 서버 환경 구축 DB 시스템 구축	A05: Injection A06: Insecure Design	M1: Improper Credential Usage
이재민	Suricata (IDS) 구축 WAF(ModSecurity) 구축	A01: Broken Access Control A04: Cryptographic Failures	M7: Insufficient Binary Protections
배주형	SIEM 구축 (Wazuh, ELK Stack)	A03: Software Supply Chain Failure A07: Authentication Failure	

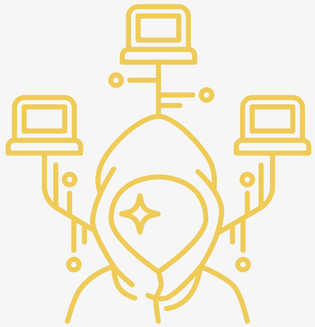
03 프로젝트 진행 과정



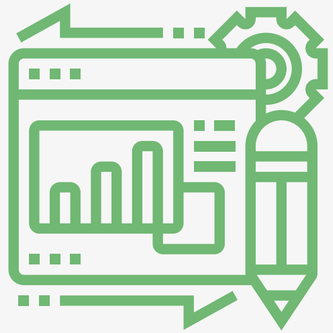
정보 수집



취약점 진단



모의해킹



대응 방안 수립



보고서 작성

04 프로젝트 사용 도구



[Kali]



[Nmap]



[OWASP-zaproxy]



[Gobuster]



[Fuff]



[curl]

A03: Software Supply Chain failure

A03:Software Supply Chain Failure

1) 취약점 진단 및 분석

웹 서버 설정 미흡으로 인한 민감한 메타 데이터 노출

- 개발 편의를 위해 설정한 GitHub 원격 저장소 정보가 유출
  공격자가 공급망의 시작점인 소스 코드 분석및 오염 시도

- Git 저장소 : nmap 스캐닝 결과
  /.git/디렉토리로 접근이 가능하다.
- 공급망 정보: 원격 저장소 주소 및 DB 접근 계정 유출
- 소스 내 하드 코딩된 DB 관리자 자격 증명 식별
  - ID: dbmaster / PW: 1234 / WEB 관리자 ID : admin
- 영향:
  - 데이터 베이스 완전 장악: 탈취된 계정을 통한 민감 정보 유출
  - 공급망 오염: 소스 코드 분석을 통한 로직 우회 및 악성 코드 주입
  - 권한 도용: DB 내 세션/권한 테이블 조작을 통한 웹 권한 탈취

```
nmap -sC -sV -p- 192.168.16.43
```

```
| http-git:
|   192.168.16.43:80/.git/
|     Git repository found!
Remotes:
  https://github.com/ggggwwww/pentest_server.git
```

```php
if(!isset($_SESSION['role']) || $_SESSION['role'] != 'admin') {
    header('Location: ../index.php');
    exit();
}
if($_SERVER['REQUEST_METHOD'] == 'POST'){

    $servername = "localhost";
    $username = "dbmaster";
    $password = "1234";
    $dbname = "pentestDB";
```

A03:Software Supply Chain Failure

2) 취약점 대응 방안

민감 정보 노출 방지를 위한 Modsecurity 정책 수립

- Modsecurity 정책 수립
  - 방어기제: 블랙리스트 기반 URL 패턴 매칭
  - 탐지 조건: 요청 URL 내 특정 문자열 포함 여부 실시간 탐지
    - .git .env
- Rule 설명
  - REQUEST_URL: 웹으로 들어오는 사용자의 요청 주소 전체를 검사 대상으로 지정
  - @contains: 대소문자 구분없이 특정 문자열 포함 여부 확인
  - deny / status 403: 조건 일치 시, 요청 거부 및 에러 반환
  - msg: 차단 발생 시 로그 파일에 기록될 메시지 설정
- Rule 동작 과정
  - 사용자 요청 → WAF 필터링 엔진 → 패턴 매칭 → 차단 및 로그 기록

```
SecRule REQUEST_URI "@contains /.git/" "id:1100501
,phase:1,deny,status:403,nolog,msg:'Source Code Le
akage Blocked'"

SecRule REQUEST_URI "\.(php|config|env)$" "id:1100
502,phase:1,deny,status:403,nolog,msg:'Direct Acce
ss to Sensitive File Denied'"
```

A03:Software Supply Chain Failure

3) 취약점 대응방안 적용

ModSecurity를 활용한 민감 정보 유출 차단

- 검증 개요
  - 도구: nmap, curl (Http 헤더 및 스크립트 분석)
  - 목적: WAF 규칙 적용 후 민감 정보 유출 차단 검증

- 테스트 결과
  - nmap 스캐닝: nmap을 통한 진단 시, git관련 정보 미출력
  - 직접적 접근 차단: /.git/config 요청시 403 에러 출력

- 최종 결론
  - 민감 정보 은닉: 외부 Git 저장소 정보 및 개발 데이터 노출 방지
    경로 노출 가능성 차단
  - 공급망 보안 확보: 소스 코드 탈취를 통한 2차 공격 가능성 제거
    시스템 안정성 강화

```
nmap -sC -sV -p- 192.168.16.43
```

```
80/tcp    open   http          Apache httpd 2.4.58 ((Ubuntu))
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: SecuriCare Main
```

```
┌──(root㉿kali)-[~]
└─# curl http://192.168.16.43/.git/config
<!DOCTYPE HTML PUBLIC "-//IETF//DTD HTML 2.0//EN">
<html><head>
<title>403 Forbidden</title>
</head><body>
<h1>Forbidden</h1>
<p>You don't have permission to access this resource.</p>
<hr>
<address>Apache/2.4.58 (Ubuntu) Server at 192.168.16.43 Port 80</address>
</body></html>
```

A07: Authentication Failures

1) 취약점 진단 및 분석

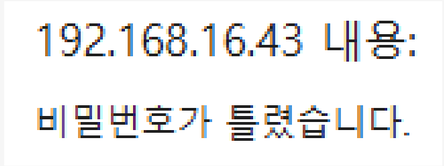
Brute Forcing Attack [무차별 대입 공격]

- 특정 암호 또는 암호화 키를 찾기 위해 가능한 모든 문자열 조합을 하나씩 차례로 대입해보는 방식

- 계정 확인: ID를 admin으로 로그인 시도 후 실패 메시지 분석
  = admin 계정이 존재함을 확인
- 공격 도구: ffuf 및 rockyou.txt (상위 1000개의 pw)
- 성공 지표: Response size 필터를 통해 유효한 데이터를 추출

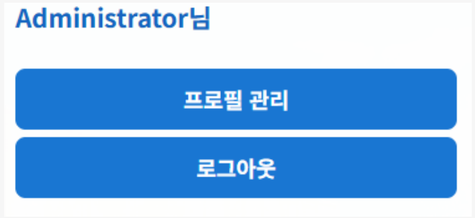
- 진단 결과: 실패 시 크기와 대조되는 크기인 200byte 식별

- 영향: 관리자 계정으로 추정되는 admin 계정의 PW 탈취
  잠재적 시스템 최고권한 획득




```
┌──(root㉿kali)-[~]
└─# ffuf -u http://192.168.16.43/auth/login.php
 -X POST -d "id=admin&pw=FUZZ" -w top1000_pass.
txt -H "Content-Type: application/x-www-form-ur
lencoded" -fs 112 -v
```

```
:: Progress: [40/1007] :: Job [1/1] :: 0 req/sec :: Duration: [
:: Progress: [316/1007] :: Job [1/1] :: 0 req/sec :: Duration:
:: Progress: [634/1007] :: Job [1/1] :: 0 req/sec :: Duration:
:: Progress: [900/1007] :: Job [1/1] :: 0 req/sec :: Duration:
[Status: 200, Size: 200, Words: 8, Lines: 1, Duration: 3ms]
| URL | http://192.168.16.43/auth/login.php
    * FUZZ: admin
```



A07: Authentication Failures

2) 취약점 대응 방안

ModSecurity를 활용한 반복적인 로그인 시도 차단

- Modsecurity 정책 수립
  - 방어기제: 상태 유지 기반 탐지 (Stateful Inspection)
  - 탐지 조건: 60초 이내 특정 경로 반복 실행

```
SecRule REQUEST_URI "@contains /auth/login.php"
"id:1100101,phase:1,deny,status:403,nolog,initco
l:ip=%{REMOTE_ADDR},setvar:ip.bf_count=+1,expire
var:ip.bf_count=60,chain,msg:'Brute Force blocke
d by mod_security from %{REMOTE_ADDR}'"
    SecRule IP:bf_count "@gt 5" "t:none"
```

- Rule 설명
  - initcol: 공격자 ip 식별
  - setvar: 요청 당 1회 count 증가
  - chain: 로그인 경로 접근 (상위 조건)
    5회 초과 확인 (하위 조건)

- Rule 동작 과정
  - 사용자 요청 → WAF 장부 (누적기록) 확인 → chain 조건 만족 시, 실행 제한

A07: Authentication Failures

3) 취약점 대응방안 적용

ModSecurity를 활용한 반복적인 로그인 시도 차단

- 검증 개요
  - 도구: ffuf (Brute Force simulation)
  - 목적: 5회 진행 후 WAF의 차단 여부 확인
- 테스트 결과
  - 로그인 시도 5회까지 정상 응답 (status 200)
  - 로그인 시도 6회부터 작업 수행 제한 (status 403)
- 최종 결론
  - 로그인 시도 5회차 후 6회차부터는 해당 ip의 로그인 시도 차단
  - 기존의 방식으로는 방어가 어려운 Brute-Forcing 공격에 대해 임계치 (5회) 기반 정책을 통한 공격 차단

```
[Status: 200, Size: 112, Words: 4, Lines: 1, Duration: 7ms]
| URL | http://192.168.16.43/auth/login.php
    * FUZZ: password1

[Status: 200, Size: 112, Words: 4, Lines: 1, Duration: 7ms]
| URL | http://192.168.16.43/auth/login.php
    * FUZZ: 12345

[Status: 200, Size: 112, Words: 4, Lines: 1, Duration: 8ms]
| URL | http://192.168.16.43/auth/login.php
    * FUZZ: chocolate

[Status: 200, Size: 112, Words: 4, Lines: 1, Duration: 8ms]
| URL | http://192.168.16.43/auth/login.php
    * FUZZ: sunshine

[Status: 200, Size: 112, Words: 4, Lines: 1, Duration: 8ms]
| URL | http://192.168.16.43/auth/login.php
    * FUZZ: monkey

[Status: 403, Size: 278, Words: 20, Lines: 10, Duration: 0ms]
| URL | http://192.168.16.43/auth/login.php
    * FUZZ: andrea
```

취약점 진단 결과 _Web

OWASP Top 10 중 8가지 보안 취약점이 발견됨

번호	OWASP TOP10
A01	**Broken Access Control**
A02	**Security Misconfiguration**
A03	**Software Supply Chain Failures**
A04	**Cryptographic Failures**

번호	OWASP TOP10
A05	**Injection**
A06	**Insecure Design**
A07	**Authentication Failures**
A09	**Logging & Alerting Failures**

최종 결론

01

Web,Mobile 진단 및 분석 결과

핵심 취약점

총 Web 8건,

Mobile 3건 식별

02

보안 구축 핵심 내용

웹·모바일 공격 탐지

실시간 공격 차단 룰 적용

ELK 기반 SIEM 환경 구축

03

개선 사항

차단 정책 정교화

신규 공격 대응 강화

Kibana 대시보드 개선

QnA

Thank you

감사합니다.